TEMPLATE P72 · AI SECURITY PROFILE (CSF 2.0 / CYBER AI PROFILE)

# AI security profile (CSF 2.0 / Cyber AI Profile)

Describes, for the NIST CSF 2.0 subcategories relevant to AI, the current level with its evidence, the target level, the gap and the action that closes it, with a summary by CSF function and by Cyber AI Profile area.

**Fernando García Varela** Version 0.3 (working draft) 19-10-2026 Draft for review

IN THIS DOCUMENT


01 Instructions for use

02 Identification

03 GV · govern

04 ID · identify

05 PR · protect

06 DE · detect

07 RS · respond and RC · recover

08 Summary by CSF function

09 Summary by Cyber AI Profile area

10 Action plan

11 Quality criteria

12 Approval and verification

13 Version control



**Legal notice and disclaimer.** SEVEN-G is a reference methodological framework provided "as is" and for information purposes only. It does not constitute legal, regulatory, financial or professional advice, nor does it guarantee compliance with any law or standard. References to general regulation (such as the EU AI Act, the GDPR, DORA or NIS2), to technical standards and to regulation specific to each sector or jurisdiction may be incomplete, may not apply to a particular case or may become out of date as a result of regulatory changes, interpretations or supervisory positions after their consultation date. **Each organisation that uses SEVEN-G is solely responsible for identifying the regulation that applies to it, verifying that it is current and certifying its own regulatory compliance**, with the appropriate qualified advice. This methodology is a generic, free aid shared with the community so that nobody has to start from scratch; each person or organisation can and should adapt it to its own use. It must not be inferred that its legally sensitive parts have been reviewed by legal counsel: those reviews, for each company or sector, are the ultimate responsibility of the company, consultant or organisation that uses it. Although every effort is made to keep it up to date, some regulation may have changed without being reflected here. To the fullest extent permitted by law, the author accepts no responsibility whatsoever for the effects of its application in any organisation or for its full applicability. The methodology does not grant certification of any kind. The author accepts no liability for any use made of this content or for any decisions taken on the basis of it. The data, figures, companies and cases in the examples are fictitious or illustrative.


**Why it matters.** Many companies govern their cybersecurity with the NIST CSF, and their risk committee already reads results in its six functions. This profile expresses AI security in that same language, with the SEVEN-G maturity scale and without a second assessment: the level of each subcategory comes from the verified questionnaire of document 11, the SEG and AG controls of document 35 provide the evidence and the gap becomes an action plan that fits into the company's cybersecurity plan.

01

# Instructions for use

| Aspect | Guidance |
|---|---|
| **When it is used** | After each verified maturity assessment in **C1** and **C5** (P34), when the company manages its cybersecurity with the NIST CSF or wants to report on AI security with its functions. The target level is set in **C2**. |
| **Who completes it** | The AI Office with information security, on the basis of the P34 answer sheet and the status of the SEG and AG controls (P18, T10). |
| **Who verifies it** | The independent verifier of the maturity assessment (11 §4.2), supported by information security for the "Own" subcategories. |
| **Who decides or approves** | The AI Committee approves the profile; the target levels are approved by the board or its board committee in C2, together with the risk appetite. |
| **Stage of the corporate cycle** | C1 and C5 (current profile), C2 (target profile), C4 (monitoring of actions and of exposure to offensive AI). |
| **Tool** | T15 · Maturity assessment calculates this profile in its "CSF profile" view (level derived from the questionnaire, own levels, targets, gap, equivalent *tier*, summaries by function and area and CSV) and saves its summary into the T01 register; T10 provides the status of the SEG and AG controls. This template is its paper or Word equivalent. |
| **Reference document** | Document 34 §5.3 (CSF 2.0 and Cyber AI Profile, the latter in draft) and §5.5 (subcategories, priorities, coverage and questions); document 35 (SEG and AG controls with their CSF function); document 11 §2.2 and §7.5. |
| **Lite versus Enterprise** | In Lite scope the company may limit the profile to the subcategories with priority 1 in Secure and Thwart, and leave the others out with a reason. |

Completion rules:

- **Current level**: the one that results from 11 §7.5 with the questions in 34 §5.5. For "Own" subcategories, the level evidenced, without exceeding the level of its reference dimension.
- **Without verified evidence, no level is evidenced**: a subcategory assessed without evidence stays at 0; one that was not assessed is left blank ("no data").
- **Evidence**: P34 questions and their answer, or SEG and AG controls with their status in T10 (met, not met, not applicable, pending).
- **Priority S · D · T**: the one proposed by the Cyber AI Profile for Secure, Defend and Thwart (1 high, 2 moderate, 3 foundational). It is indicative while the profile remains a draft and **does not underpin *gate* criteria** (34 §5.3).

- **Gap** = target level − current level. **Equivalent *tier***: a view calculated with the table in 11 §2.2 (0–1 → 1; 2 → 2; 3 → 3; 4–5 → 4). CSF *tiers* describe the rigour of the whole organisation: the one in each row is only a reading of the level, not the company's *tier*.
- The company may add other CSF 2.0 subcategories if its context calls for them, with the same treatment.

02

# Identification

| Field | Content | Guidance |
|---|---|---|
| **Company and perimeter** | | AI systems included: all of them, those of a unit or those of an autonomy level. |
| **Profile identifier** | | Proposed format PS-YYYY-MM. |
| **Source maturity assessment** | | Identifier (EM-YYYY-MM), assessment type and cut-off date of P34. |
| **Reference versions** | | NIST CSF 2.0 (CSWP 29); Cyber AI Profile (NIST IR 8596) in the version consulted, with its status (draft or final). |
| **CSF *tier* the company declares for its cybersecurity, if it does** | | Recorded only; this profile does not calculate it. |
| **Date of approval of the target profile** | | C2 minutes. |

03

# GV · govern

| Subcategory | Priority S · D · T | Level from document 11 | Current level (0–5) | Evidence | Target level | Gap | Equiv. *tier* | Action |
|---|---|---|---|---|---|---|---|---|
| **GV.OC-03** | 3 · 1 · 3 | D6.05, D6.12 (D6) | | | | | | |
| **GV.OC-04** | 1 · 1 · 3 | Own (D4) | | | | | | |
| **GV.OC-05** | 1 · 2 · 3 | Own (D4) | | | | | | |
| **GV.RM-02** | 2 · 2 · 1 | D1.05 (D1) | | | | | | |

| Subcategory | Priority S · D · T | Level from document 11 | Current level (0–5) | Evidence | Target level | Gap | Equiv. *tier* | Action |
|---|---|---|---|---|---|---|---|---|
| **GV.RM-07** | 3 · 1 · 3 | D2.07 (D2) | | | | | | |
| **GV.RR-01** | 3 · 1 · 2 | D1.01, D1.09 (D1) | | | | | | |
| **GV.RR-02** | 3 · 1 · 2 | D1.07, D1.08 (D1) | | | | | | |
| **GV.RR-03** | 2 · 2 · 1 | Own (D1) | | | | | | |
| **GV.RR-04** | 1 · 3 · 1 | Own (D5) | | | | | | |
| **GV.PO-01** | 3 · 1 · 3 | D1.04 (D1) | | | | | | |
| **GV.PO-02** | 1 · 1 · 2 | D6.12 (D6) | | | | | | |
| **GV.SC-03** | 1 · 2 · 3 | D6.08 (D6) | | | | | | |
| **GV.SC-07** | 1 · 1 · 3 | D6.08 (D6) | | | | | | |

04

# ID · identify

| Subcategory | Priority S · D · T | Level from document 11 | Current level (0–5) | Evidence | Target level | Gap | Equiv. *tier* | Action |
|---|---|---|---|---|---|---|---|---|
| **ID.AM-03** | 1 · 2 · 2 | D3.07 (D3) | | | | | | |
| **ID.AM-07** | 1 · 1 · 3 | D3.03, D3.05 (D3) | | | | | | |
| **ID.AM-08** | 1 · 3 · 2 | D6.05 (D6) | | | | | | |
| **ID.RA-01** | 1 · 1 · 1 | D6.10 (D6) | | | | | | |

| Subcategory | Priority S · D · T | Level from document 11 | Current level (0–5) | Evidence | Target level | Gap | Equiv. *tier* | Action |
|---|---|---|---|---|---|---|---|---|
| **ID.RA-03** | 1 · 1 · 1 | D6.08 (D6) | | | | | | |
| **ID.RA-04** | 1 · 1 · 1 | D6.06 (D6) | | | | | | |
| **ID.RA-06** | 3 · 2 · 1 | D6.06 (D6) | | | | | | |
| **ID.RA-07** | 2 · 1 · 1 | D4.04 (D4) | | | | | | |
| **ID.RA-08** | 3 · 3 · 1 | Own (D6) | | | | | | |
| ***(illustrative example)* ID.RA-01** | 1 · 1 · 1 | D6.10 (D6) | 3 | D6 at 3; D6.10 (level 4) at "No": no periodic AI-specific security testing campaigns. | 4 | 1 | 3 | AM-2026-05 |

05

# PR · protect

| Subcategory | Priority S · D · T | Level from document 11 | Current level (0–5) | Evidence | Target level | Gap | Equiv. *tier* | Action |
|---|---|---|---|---|---|---|---|---|
| **PR.AA-01** | 1 · 2 · 1 | D6.08 (D6) | | | | | | |
| **PR.AA-05** | 1 · 2 · 1 | D6.08 (D6) | | | | | | |
| **PR.AT-01** | 1 · 1 · 1 | D5.05 (D5) | | | | | | |
| **PR.AT-02** | 2 · 1 · 1 | D5.06 (D5) | | | | | | |
| **PR.DS-01** | 1 · 1 · 2 | D3.05 (D3) | | | | | | |
| **PR.DS-10** | 1 · 1 · 3 | Own (D6) | | | | | | |
| **PR.PS-01** | 1 · 1 · 3 | D4.04 (D4) | | | | | | |
| **PR.PS-02** | 3 · 3 · 1 | Own (D4) | | | | | | |

| Subcategory | Priority S · D · T | Level from document 11 | Current level (0–5) | Evidence | Target level | Gap | Equiv. *tier* | Action |
|---|---|---|---|---|---|---|---|---|
| **PR.PS-03** | 3 · 2 · 1 | Own (D4) | | | | | | |
| **PR.PS-04** | 1 · 1 · 1 | D4.08 (D4) | | | | | | |
| **PR.PS-05** | 2 · 2 · 1 | D6.09 (D6) | | | | | | |
| **PR.IR-01** | 2 · 2 · 1 | D4.03 (D4) | | | | | | |
| **PR.IR-03** | 2 · 1 · 2 | D4.06, D4.12 (D4) | | | | | | |

06

# DE · detect

| Subcategory | Priority S · D · T | Level from document 11 | Current level (0–5) | Evidence | Target level | Gap | Equiv. *tier* | Action |
|---|---|---|---|---|---|---|---|---|
| **DE.CM-01** | 2 · 1 · 1 | Own (D4) | | | | | | |
| **DE.CM-06** | 1 · 2 · 2 | D6.08 (D6) | | | | | | |
| **DE.CM-09** | 1 · 1 · 2 | D4.05 (D4) | | | | | | |
| **DE.AE-03** | 3 · 1 · 2 | Own (D4) | | | | | | |
| **DE.AE-04** | 3 · 1 · 2 | D6.07 (D6) | | | | | | |
| **DE.AE-06** | 3 · 2 · 1 | D4.05 (D4) | | | | | | |
| **DE.AE-07** | 3 · 2 · 1 | Own (D6) | | | | | | |

07

# RS · respond and RC · recover

| Subcategory | Priority S · D · T | Level from document 11 | Current level (0–5) | Evidence | Target level | Gap | Equiv. *tier* | Action |
|---|---|---|---|---|---|---|---|---|
| **RS.MA-02** | 2 · 1 · 2 | D6.07 (D6) | | | | | | |
| **RS.MA-03** | 2 · 1 · 1 | D6.07 (D6) | | | | | | |
| **RS.AN-03** | 1 · 1 · 1 | D6.07 (D6) | | | | | | |
| **RS.AN-06** | 3 · 3 · 1 | D6.07 (D6) | | | | | | |
| **RS.AN-07** | 1 · 2 · 2 | D4.08 (D4) | | | | | | |
| **RC.RP-02** | 3 · 1 · 3 | D4.06 (D4) | | | | | | |

### Subcategories added or excluded

| Subcategory | Added or excluded | Reason | Who decides it |
|---|---|---|---|
| | | | |

08

# Summary by CSF function

| Function | Subcategories in the profile | With level · no data | Minimum current level | Most frequent current level | Subcategories with a gap |
|---|---|---|---|---|---|
| **GV · govern** | 13 | | | | |
| **ID · identify** | 9 | | | | |
| **PR · protect** | 13 | | | | |
| **DE · detect** | 7 | | | | |

| Function | Subcategories in the profile | With level · no data | Minimum current level | Most frequent current level | Subcategories with a gap |
|---|---|---|---|---|---|
| **RS · respond** | 5 | | | | |
| **RC · recover** | 1 | | | | |
| **Total** | **48** | | | | |

09

# Summary by Cyber AI Profile area

Each area is summarised with the subcategories to which the profile gives priority 1 in it.

| Area | What it covers | Subcategories with priority 1 | Minimum current level | Subcategories with a gap | Coverage in SEVEN-G |
|---|---|---|---|---|---|
| **Secure** | Protecting the components of AI systems. | 23 | | | 35 §3–§8; SEG-01 to SEG-14, SEG-26 and SEG-27; AG-01 to AG-20 |
| **Defend** | Using AI in the company's cyber defence. | 28 | | | 35 §9.3; SEG-21 to SEG-25 and autonomy levels A0–A3 |
| **Thwart** | Thwarting attacks that use AI. | 24 | | | 35 §9; SEG-13, SEG-15 to SEG-19 |

10

# Action plan

Actions are added to the improvement plan of the maturity report (P34 §6.6) with the same code and, if the company has a cybersecurity plan, they are also reflected in it.

| Code | Subcategories | SEG or AG controls | Action | Owner | Deadline | Closure criterion |
|---|---|---|---|---|---|---|
| **AM-YYYY-NN** | | | | | | |

| Code | Subcategories | SEG or AG controls | Action | Owner | Deadline | Closure criterion |
|---|---|---|---|---|---|---|
| ***(illustrative example)*** **AM-2026-05** | ID.RA-01, ID.RA-03 | SEG-11, AG-18 | Six-monthly adversarial testing campaign on exposed generative systems and A2 agents. | Information security | 31-03-2027 | Two campaigns with a P53 report and high findings closed. |

11

# Quality criteria

| # | Check | Status |
|---|---|---|
| **1** | The profile is derived from a verified maturity assessment, identified in section 2. | Met · Not met · Not applicable · Pending |
| **2** | Each derived level applies the rule in 11 §7.5 with the questions in 34 §5.5; no level has been set without evidence. | |
| **3** | Subcategories that were not assessed appear as "no data", not as 0. | |
| **4** | The Cyber AI Profile priorities are presented as indicative and the status of the source (draft or final) is recorded. | |
| **5** | No equivalent *tier* of a row is presented as the company's CSF *tier*. | |
| **6** | The target levels are approved in C2 and are consistent with the risk appetite and with the minimums by autonomy level (35 §5.3). | |
| **7** | Each gap has an action with an owner, deadline and closure criterion in P34 §6.6. | |

12

# Approval and verification

| Function | SEVEN-G role | Name and position | Date | Signature or reference |
|---|---|---|---|---|
| **Prepares the profile** | AI Office with information security | | | |

| Function | SEVEN-G role | Name and position | Date | Signature or reference |
|---|---|---|---|---|
| **Verifies** | Independent verifier of the maturity assessment | | | |
| **Approves the profile and proposes the targets** | AI Committee | | | |
| **Approves the target levels** | Board or its board committee (C2) | | | |

Segregation of duties: whoever designs or implements a control does not assess the subcategories that the control evidences; the verifier has not taken part in the assessment.

13

# Version control

### Completed document

| Version | Date | Author | Changes |
|---|---|---|---|
| | | | |

### Template

| Version | Date | Changes |
|---|---|---|
| **0.1** | 25-09-2026 | First version. Current and target profile of the 48 NIST CSF 2.0 subcategories with high priority in some area of the Cyber AI Profile (initial preliminary draft of December 2025), on the 0–5 scale of document 11, with the level derived from the questionnaire (11 §7.5), the gap, the equivalent *tier* as a view and the summaries by CSF function and by Secure, Defend and Thwart area. |
| **0.2** | 25-09-2026 | The Defend area refers to 35 §9.3 and controls SEG-21 to SEG-25. |
| **0.3** | 19-10-2026 | The Secure area includes the corporate AI gateway (SEG-26) and the corporate agent test bench (SEG-27) (D159). |

# External sources cited

Links to the official or primary source, checked before publication. Always verify the version in force on the date of use.

**Cybersecurity Framework Profile for Artificial Intelligence (Cyber AI Profile): NIST Community Profile, NIST IR 8596 (Initial Preliminary Draft)** · https://csrc.nist.gov/pubs/ir/8596/iprd · National Institute of Standards and Technology (NIST), NCCoE · 16-12-2025

**The NIST Cybersecurity Framework (CSF) 2.0, NIST CSWP 29** · https://csrc.nist.gov/pubs/cswp/29/the-nist-cybersecurity-framework-csf-20/final · National Institute of Standards and Technology (NIST), Departamento de Comercio de EE. UU. · 26-02-2024